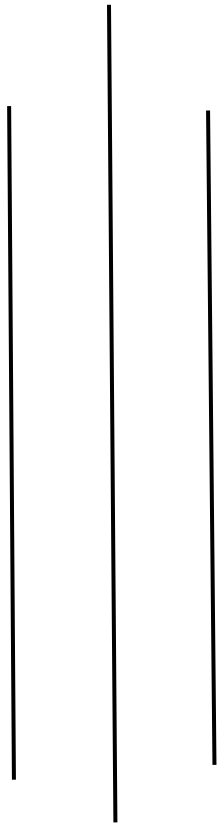
WEEK 4: INTERNSHIP REPORT



Submitted By: Yanji Pakhrin

To

OneCover Nepal

TABLE OF CONTENTS

CHAPTER 1 INTRODUCTION 1

1.1 Background 1

1.2 Problem Statement 1

1.3 Objective 2

1.4 Scope 2

1.5 Limitations 2

CHAPTER 2 : INCIDENT INVESTIGATION 3

2.1 Incident Summary 3

2.2 Evidence Analyzed 4

2.3 Investigation Methodology 5

2.4 Findings 5

2.5 Indicators of Compromise (IOCs) 6

2.6 Timeline 7

2.7 Possible impact 8

2.8 Recommendations 8

CHAPTER 3 EVIDENCE AND LEARNINGS 9

3.1 Screenshots 9

3.2 Key learnings 15

3.3 Conclusion 15

LIST OF FIGURES

Figure 3.1: Phishing kit archive 9
Figure 3.2: Phishing kit unzip 9
Figure 3.3: Moved into the extracted pankewk directory 9
Figure 3.4: metamask directory 10
Figure 3.5: Files index.html and metamask.html 10
Figure 3.6: Victim's location 11
Figure 3.7: log/log.txt holds the stolen seed phrases 11
Figure 3.8: Telegram exfiltration in metamask.php 12
Figure 3.9: Target wallet metamask 12
Figure 3.10: Kit uses sypexgeo for victim info 13
Figure 3.11: Data sent through Telegram, bot token and ID were recovered 14
Figure 3.12: Kit developer's handle 14

LIST OF TABLES

Table 2.1: Evidence Analyzed..... 4
Table 2.2: Indicators of Compromise..... 6
Table 2.3: Timeline 7

CHAPTER 1 INTRODUCTION

1.1 Background

Decentralized Finance (DeFi) platform provides a financial service through block-chain based applications and cryptocurrency wallets. Users interact with these platforms by connecting their cryptocurrency wallets.

In the reported incident, DeFi platform received multiple complaints from users regarding unauthorized withdrawals of funds. A forensic review identified a phishing website designed to impersonate the legitimate PancakeSwap platform. The phishing site attempted to mislead victim into entering their cryptocurrency wallet seed phrases. The collected information was then exfiltered through a Telegram bot, while the phishing kit was hosted on a compromised server.

This incident demonstrated how phishing, compromised infrastructure, credential theft, and external communication services. Threat intelligence analysis can help investigators identify such activity and understand the techniques used by the attacker.

1.2 Problem Statement

The incident involves a phishing website impersonating PancakeSwap to collect victim's wallet seed phrases and transmit them to an attacker-controlled Telegram bot. The compromised sever may make it difficult to identify the attacker directly. Therefore, this investigation focuses on analyzing the evidence, identifying IoCs, examining the phishing infrastructure and data exfiltration methods, and investigating the attacker's aliases and Telegram identifiers.

1.3 Objective

- To analyze evidence from the cryptocurrency phishing incident.
- To identify phishing infrastructure and key IoCs.
- To identify relevant domains, URLs, IP address, files, and Telegram identifiers.
- To develop a timeline of the observed activities.
- To provide recommendations for detection, prevention, and incident response.

1.4 Scope

The scope of this investigation covers the analysis of the phishing website, its infrastructure and related evidence.

1.5 Limitations

The investigation is limited by the available evidence and threat-intelligence data. Some infrastructure details, timestamps, or attacker identities may not be directly observable. Compromised infrastructure and online aliases may also make attribution difficult. Therefore, conclusions are based on available evidence and include appropriate uncertainty.

CHAPTER 2 : INCIDENT INVESTIGATION

2.1 Incident Summary

A decentralized finance (DeFi) platform received complaints about unauthorized withdrawals from user's cryptocurrency wallets. The incident involved a phishing website designed to impersonate PancakeSwap and trick users into providing their wallet seed phrases.

During the investigation, a fake wallet interface was found that collected seed phrases through a PHP script. The script also collected the user's IP address, location, and browser information. The collected data was sent to a Telegram bot and stored in a local log file.

The purpose of this investigation is to analyze the available evidence, identify Indicators of Compromise (IOCs), determine the observed data collection and exfiltration methods, examine relevant attacker infrastructure and identifiers, and provide recommendations for detecting and preventing similar phishing attacks.

2.2 Evidence Analyzed

The following files and directories from the provided phishing kit were examined during the investigation

Table 2.1: Evidence Analyzed

S.N.	Evidence	Finding	Significance
1	metamask/metamask.php	The PHP script receives the submitted seed phrase and collects the user's IP address, location, and browser user-agent.	This indicates that the phishing kit was designed to collect both wallet credentials and victim information.
2	log/log.txt	The file contains data submitted through the phishing interface.	This indicates that collected information was also stored locally on the server.
3	metamask/index.html	The page contains a fake wallet interface with a seed-phrase input field and code that sends the entered value to metamask.php	This establishes the connection between the phishing interface and the server-side data collection mechanism.

The main focus of the investigation was on the HTML, PHP, and log files because they provided direct evidence of the seed-phrase collection, data processing, exfiltration, and local storage mechanisms.

2.3 Investigation Methodology

The investigation was conducted in a Kali Linux virtual machine. The assigned phishing kit file was downloaded. The downloaded file was then extracted for analysis.

After extraction, the directory structure and available files were reviewed to identify relevant evidence. The main files related to the investigation were then examined, including the fake wallet webpage, PHP backend script, and log file.

The source code was checked to understand how user data was collected and sent to the attacker. Telegram related references and other suspicious indicators were searched for. The collected evidence was then used to understand the attack flow and identify relevant IOCs.

2.4 Findings

The investigation identified the following suspicious activities:

- A fake wallet interface was used to trick users into entering their cryptocurrency seed phrases.
- The submitted seed phrase was sent to a PHP script for processing.
- The PHP script collected additional information, including the user's IP address, location and browser information.
- The collected information was exfiltrated through the Telegram Bot API.
- The submitted data was also stored locally in log/log.txt.
- The log directory was restricted to local access through its .htaccess configuration.

2.5 Indicators of Compromise (IOCs)

Table 2.2: Indicators of Compromise

S.N.	IOC Type	Indicator	Description
1	File	metamask/index.html	Fake wallet interface used to collect seed phrases
2	File	metamask/metamask.php	PHP script used to process and exfiltrate collected data
3	File	log/log.txt	Local file used to store collected data
4	Domain	api.telegram.org	Telegram Bot API endpoint used for data exfiltration
5	Domain	api.sypexgeo.net	Used to obtain geolocation information
6	IP-related	$_SERVER['REMOTE_ADDR']	Captures the victim's IP address
7	Alias	j1j1b1s@m3r0	Alias-like string found in the PHP source-code comment
8	Telegram	Bot/chat identifiers	Identifiers embedded in the PHP script

2.6 Timeline

Table 2.3: Timeline

Stage	Activity	Evidence
1	Victim accesses the phishing website and is presented with a fake wallet interface.	metamask/index.html
2	Victim enters their cryptocurrency wallet seed phrase.	metamask/index.html
3	The entered seed phrase is sent to the PHP backend for processing.	metamask/index.html, metamask/metamask.php
4	The PHP script collects the seed phrase along with the victim's IP address, location, and browser information.	metamask/metamask.php
5	The collected information is sent to a Telegram bot through the Telegram Bot API.	metamask/metamask.php
6	The submitted data is also stored in the local log/log.txt file.	metamask/metamask.php, log/log.txt

2.7 Possible impact

The phishing attack could cause serious problems for users. The main risk is the theft of cryptocurrency wallet seed phrases. If an attacker gets a seed phrase, they may be able to access the victim's wallet and steal the available funds.

The phishing script also collected the victim's IP address, location, and browser information. This information could be misused for further attacks. The collected seed phrases were also stored in a local log file, which could create an additional risk of sensitive information being exposed.

The fake wallet website could also reduce user's trust in the affected platform. However, the actual amount of financial loss cannot be confirmed from the available evidence because no wallet transaction records were analyzed.

2.8 Recommendations

Based on the investigation, the following recommendations are suggested:

- Users should be educated about phishing attacks and fake websites.
- Users should never share their cryptocurrency wallet seed phrases with unknown websites or people.
- The website address should be checked before entering any wallet information.
- Phishing files should be removed from the compromised server.
- The affected server should be properly secured to prevent similar attacks.
- Security teams should regularly monitor websites and network activity for suspicious behavior.
- Organizations should provide regular security awareness training to users and employees.
- A proper incident response process should be followed to detect and handle phishing attacks quickly.

CHAPTER 3 EVIDENCE AND LEARNINGS

3.1 Screenshots



Figure 3.1: Phishing kit archive

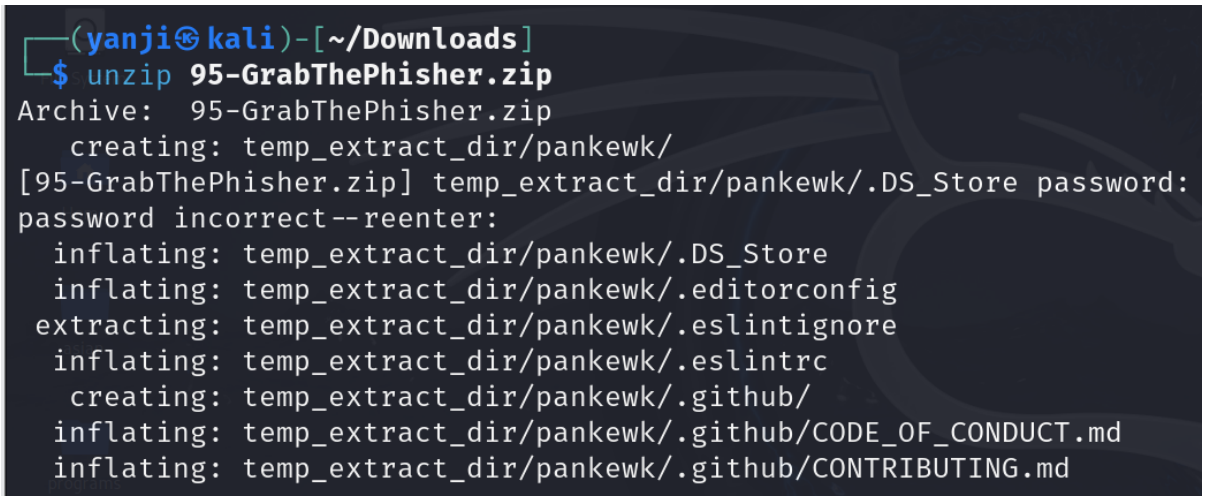


Figure 3.2: Phishing kit unzip



Figure 3.3: Moved into the extracted pankewk directory

```
┌──(yanji㉿kali)-[~/Downloads/temp_extract_dir/pankewk]
└─$ ls metamask
fonts  index.html  metamask.php
```

Figure 3.5: Files index.html and metamask.html

```
┌──(yanji㉿kali)-[~/Downloads/temp_extract_dir/pankewk]
└─$ ls -l
total 776
drwx------ 3 yanji yanji   4096 Jul 23  2022 _next
-rw-rw-r-- 1 yanji yanji 151073 Jun 29  2022 background.
jpg
-rw-rw-r-- 1 yanji yanji 122910 Jun 29  2022 background1
.jpg
-rw-rw-r-- 1 yanji yanji  43879 Jun 29  2022 background2
.jpg
drwx------ 2 yanji yanji   4096 Jul 19  2022 cgi-bin
-rw-rw-r-- 1 yanji yanji 116129 Jun 29  2022 favicon.ico
drwx------ 4 yanji yanji   4096 Jul 23  2022 images
-rw-rw-r-- 1 yanji yanji 300563 Jul  1  2022 index.html
drwx------ 2 yanji yanji   4096 Jul 23  2022 log
-rw-rw-r-- 1 yanji yanji  22919 Jun 29  2022 logo.png
drwx------ 3 yanji yanji   4096 Jul 23  2022 metamask
```

Figure 3.4: metamask directory

```
┌──(yanji㉿kali)-[~/Downloads/temp_extract_dir/pankewk]
└─$ cat metamask/metamask.php
<?php

$request = file_get_contents("http://api.sypexgeo.net/json/".$_SERVER['REMO
TE_ADDR']);
$array = json_decode($request);
$geo = $array→country→name_en;
$city = $array→city→name_en;
$date = date("m.d.Y"); //aaja


/*
 With love and respect to all the hustler out there,
 This is a small gift to my brothers,
 All the best with your luck,

 Regards,
 j1j1b1s@m3r0

  */
```

Figure 3.6: Victim's location

```
┌──(yanji㉿kali)-[~/Downloads/temp_extract_dir/panke
wk]
└─$ ls log
log.txt

┌──(yanji㉿kali)-[~/Downloads/temp_extract_dir/panke
wk]
└─$ cat log/log.txt
number edge rebuild stomach review course sphere abs
urd memory among drastic total
bomb stairs satisfy host barrel absorb dentist priso
n capital faint hedgehog worth
father also recycle embody balance concert mechanic
believe owner pair muffin hockey
```

Figure 3.7: log/log.txt holds the stolen seed phrases

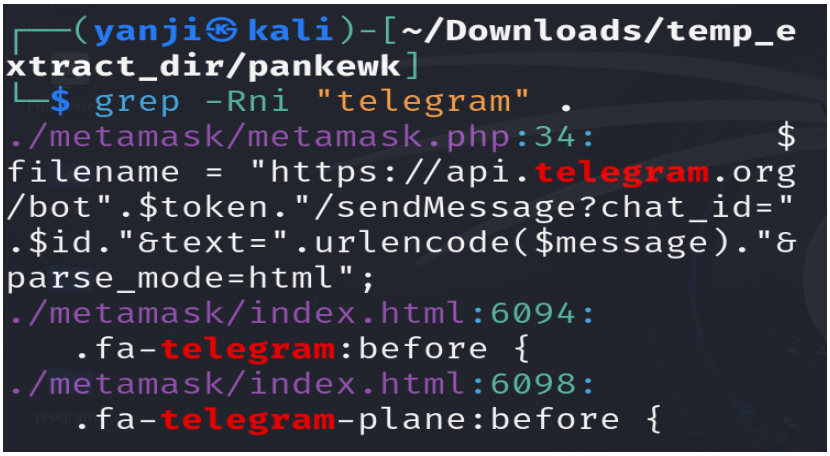


Figure 3.8: Telegram exfiltration in metamask.php

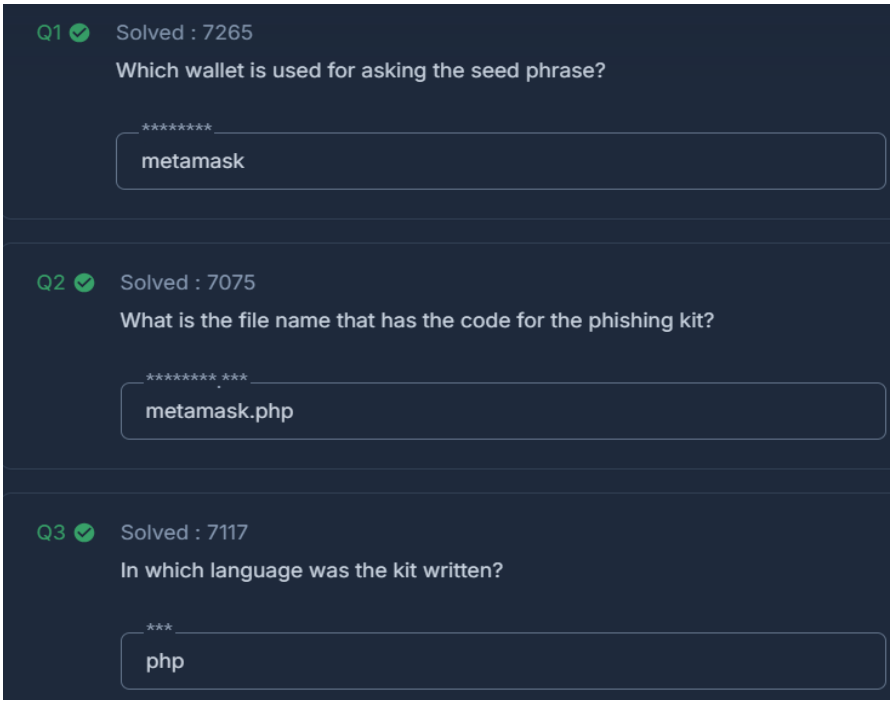


Figure 3.9: Target wallet metamask

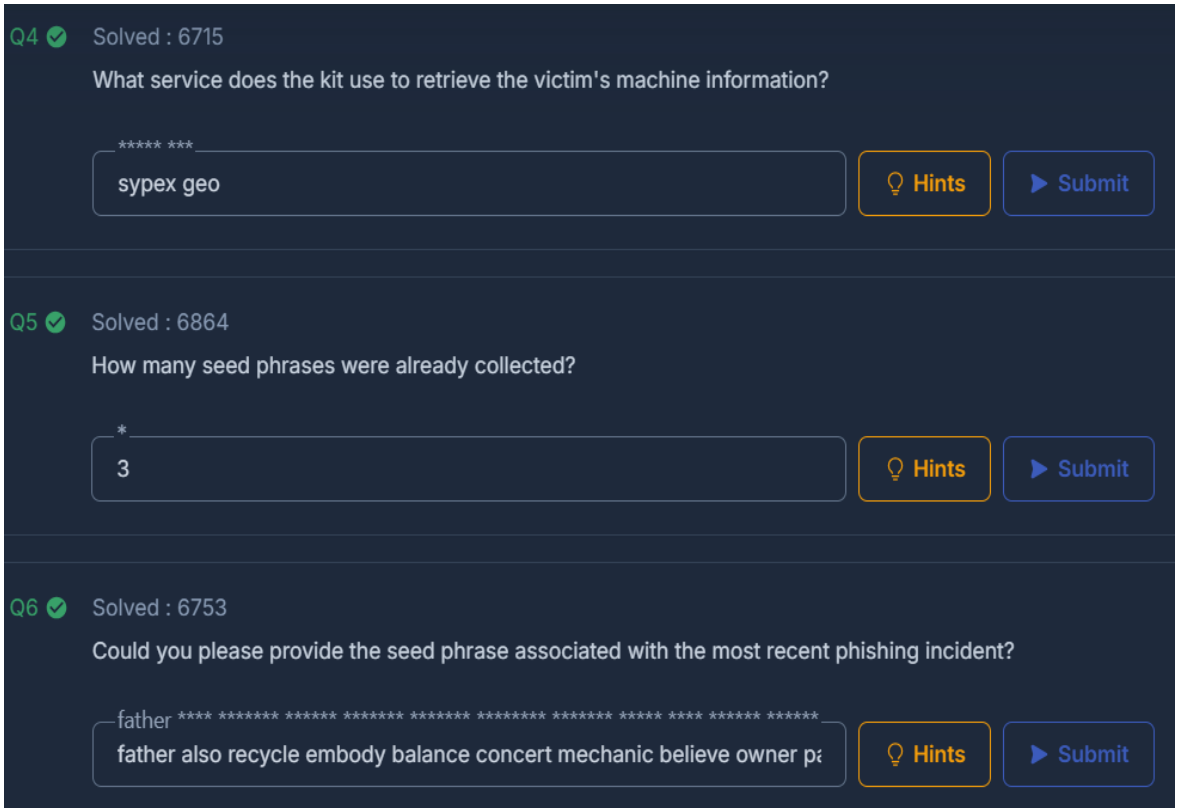


Figure 3.10: Kit uses sypexgeo for victim info

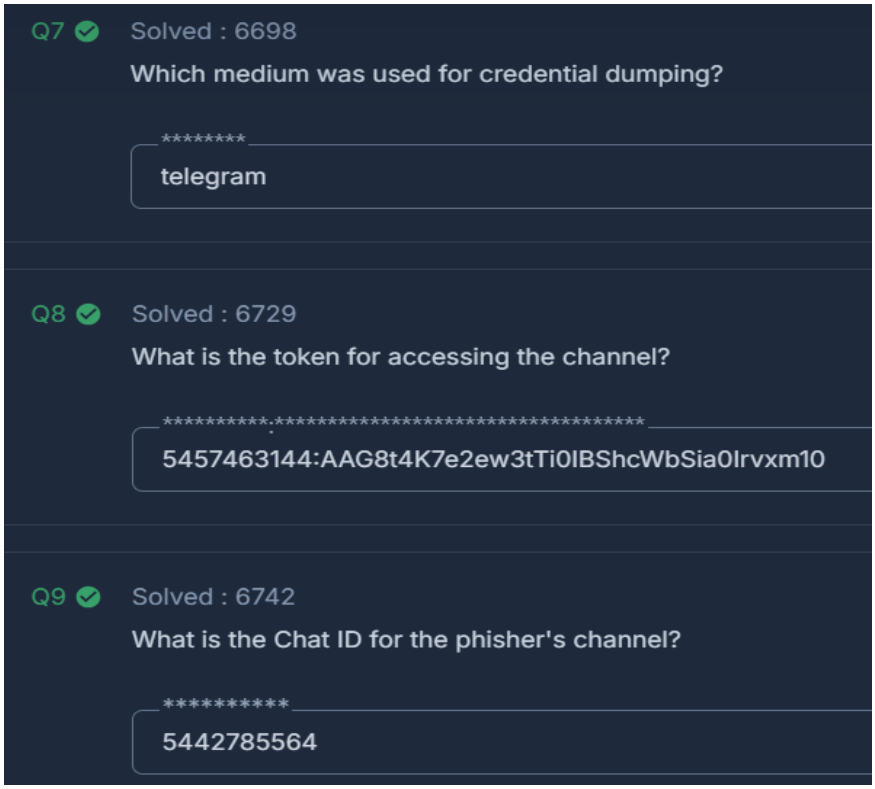


Figure 3.11: Data sent through Telegram, bot token and ID were recovered

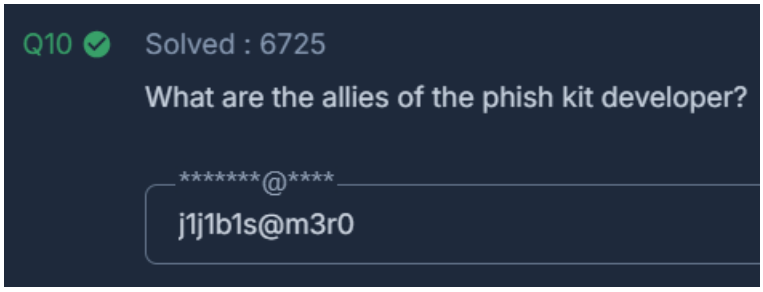


Figure 3.12: Kit developer's handle

3.2 Key learnings

In this week the key learnings are:

- I learnt about phishing attacks.
- I learnt about digital forensics and how an investigation is done considering different scenarios.
- I learnt about the impact of phishing and also measures to avoid or mitigate such attacks.

3.3 Conclusion

In conclusion, the investigation demonstrated how attackers use a phishing website to collect user's seed phrases and exfiltrate the stolen information through Telegram. The investigation identified the phishing infrastructure, suspicious activities and relevant IOCs associated with the attack. This investigation highlights the importance of phishing awareness and prevention similar attacks.